Estado	Finalizado
Comenzado	viernes, 6 de noviembre de 2026, 16:49
Completado	viernes, 6 de noviembre de 2026, 17:23
Duración	33 minutos 21 segundos
Calificación	**100,00** de 100,00

Pregunta 1

Correcta

Se puntúa 1,00 sobre 1,00

Una app tiene un ContentProvider exportado y protegido con permiso signature. ¿Cuál es la interpretación inicial más adecuada?

a. La protección signature limita la invocación a aplicaciones firmadas con la misma clave, por lo que debe evaluarse el diseño antes de considerarlo una falla.
b. El provider debe clasificarse directamente como SQL injection.
c. El provider es necesariamente vulnerable porque está exportado.
d. El permiso signature es equivalente a normal si la aplicación tiene targetSdk alto.

La respuesta correcta es: La protección signature limita la invocación a aplicaciones firmadas con la misma clave, por lo que debe evaluarse el diseño antes de considerarlo una falla.

Pregunta 2

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diferencia esencial introduce certificate pinning respecto de la confianza TLS normal del sistema?

a. Convierte el tráfico en Base64.
b. Deshabilita completamente TLS.
c. Obliga a usar HTTP.
d. La app compara contra un certificado o clave pública esperada en lugar de confiar únicamente en cualquier CA aceptada por el sistema.

La respuesta correcta es: La app compara contra un certificado o clave pública esperada en lugar de confiar únicamente en cualquier CA aceptada por el sistema.

Pregunta 3

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué evidencia aporta mejor apktool frente a unzip cuando se revisa AndroidManifest.xml?

a. unzip puede reconstruir automáticamente Java desde classes.dex.
b. apktool elimina la firma y por eso revela permisos ocultos.
c. apktool puede decodificar el Manifest binario a XML legible y reconstruir recursos asociados. ✓
d. unzip detecta componentes exportados mejor que apktool.

La respuesta correcta es: apktool puede decodificar el Manifest binario a XML legible y reconstruir recursos asociados.

Pregunta 4

Correcta

Se puntúa 1,00 sobre 1,00

Un script Frida imprime credenciales reales mientras instrumenta una app autorizada. ¿Qué criterio de evidencia debe aplicarse?

a. Publicarlas para demostrar reproducibilidad.
b. Usarlas para probar otros servicios.
c. Conservar únicamente lo necesario, evitar exposición innecesaria y documentar la condición sin difundir secretos reales. ✓
d. Copiar todas las credenciales al informe.

La respuesta correcta es: Conservar únicamente lo necesario, evitar exposición innecesaria y documentar la condición sin difundir secretos reales.

Pregunta 5

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diferencia hay entre observar y reemplazar una función con Frida?

a. Observar registra argumentos o retornos preservando la lógica; reemplazar puede alterar deliberadamente el comportamiento de la función. ✓
b. Observar requiere root y reemplazar no.
c. Reemplazar solo funciona con métodos nativos.
d. No existe diferencia.

La respuesta correcta es: Observar registra argumentos o retornos preservando la lógica; reemplazar puede alterar deliberadamente el comportamiento de la función.

Pregunta 6

Correcta

Se puntúa 1,00 sobre 1,00

Un Service exportado ejecuta una exportación de datos cuando recibe un Intent, sin comprobar identidad ni autorización del llamador. ¿Cuál es el problema principal?

a. El uso de startService en vez de bindService.
b. El hecho de que el Service no tenga interfaz gráfica.
c. La existencia del Service.
d. La posibilidad de invocar una operación privilegiada desde otra aplicación sin una autorización efectiva. ✓

La respuesta correcta es: La posibilidad de invocar una operación privilegiada desde otra aplicación sin una autorización efectiva.

Pregunta 7

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes escenarios demuestra mejor M9 Insecure Data Storage?

a. Una URL pública incluida en resources.
b. Una variable booleana de interfaz almacenada en memoria.
c. Un permiso INTERNET declarado en el Manifest.
d. Una base SQLite local con notas sensibles accesibles en texto claro tras obtener legítimamente el sandbox durante la evaluación. ✓

La respuesta correcta es: Una base SQLite local con notas sensibles accesibles en texto claro tras obtener legítimamente el sandbox durante la evaluación.

Pregunta 8

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diferencia conceptual existe entre almacenar un dato en SharedPreferences y usar EncryptedSharedPreferences?

a. EncryptedSharedPreferences impide toda ingeniería inversa del APK.
b. SharedPreferences siempre se almacena fuera del sandbox.
c. La segunda busca cifrar claves y valores utilizando mecanismos asociados al Keystore en lugar de dejar contenido sensible legible directamente. ✓
d. No existe diferencia de seguridad.

La respuesta correcta es: La segunda busca cifrar claves y valores utilizando mecanismos asociados al Keystore en lugar de dejar contenido sensible legible directamente.

Pregunta 9

Correcta

Se puntúa 1,00 sobre 1,00

Un componente necesita ser accesible por otras aplicaciones del mismo fabricante. ¿Qué diseño ofrece una barrera más fuerte según el modelo descrito?

a. android:exported="true" protegido con un permiso protectionLevel="normal".
b. android:exported="false" y un intent-filter implícito.
c. android:exported="true" protegido con un permiso protectionLevel="signature". ✓
d. android:exported="true" sin permisos.

La respuesta correcta es: android:exported="true" protegido con un permiso protectionLevel="signature".

Pregunta 10

Correcta

Se puntúa 1,00 sobre 1,00

Una app acepta certificados de usuario debido a su network_security_config. ¿Qué demuestra esto?

a. Que Android ignora el Manifest.
b. Que el servidor no utiliza TLS.
c. Certificate pinning fuerte.
d. Una política de confianza más permisiva que puede facilitar MITM en condiciones donde el atacante logra instalar una CA de usuario. ✓

La respuesta correcta es: Una política de confianza más permisiva que puede facilitar MITM en condiciones donde el atacante logra instalar una CA de usuario.

Pregunta 11

Correcta

Se puntúa 1,00 sobre 1,00

Un informe afirma que una Activity exportada permite bypass de autenticación, pero solo incluye el fragmento del Manifest. ¿Qué falta para sostener mejor el hallazgo?

a. Una validación reproducible que muestre que el acceso externo alcanza efectivamente contenido o acción protegida. ✓
b. Una captura de Burp aunque no haya tráfico.
c. Un logo de la aplicación.
d. El código fuente completo del servidor.

La respuesta correcta es: Una validación reproducible que muestre que el acceso externo alcanza efectivamente contenido o acción protegida.

Pregunta 12

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué secuencia refleja mejor la preparación de Frida antes de instrumentar una aplicación?

a. Configurar Burp, habilitar JavaScript y ejecutar frida-trace sin servidor.
b. Consultar ABI, usar frida-server compatible, copiarlo, dar permisos, iniciarlo y verificar con frida-ps -U. ✓
c. Reempaquetar el APK y firmarlo con el certificado de Burp.
d. Instalar objection, ejecutar jadx y después calcular el hash.

La respuesta correcta es: Consultar ABI, usar frida-server compatible, copiarlo, dar permisos, iniciarlo y verificar con frida-ps -U.

Pregunta 13

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué remediación aborda mejor una cadena compuesta por deep link -> URL externa -> WebView -> addJavascriptInterface?

a. Permitir file:// para aislar el contenido.
b. Validar estrictamente el deep link y destino, restringir contenido del WebView y eliminar o minimizar interfaces JavaScript expuestas. ✓
c. Usar un esquema custom más corto.
d. Agregar más métodos al puente para controlar errores.

La respuesta correcta es: Validar estrictamente el deep link y destino, restringir contenido del WebView y eliminar o minimizar interfaces JavaScript expuestas.

Pregunta 14

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué mitigación es más adecuada para un deep link que dispara una acción sensible?

a. Validar esquema, host, ruta, parámetros y estado de autorización antes de ejecutar la acción. ✓
b. Confiar en que el usuario hizo clic voluntariamente.
c. Marcar la Activity como debuggable.
d. Ocultar la ruta usando Base64.

La respuesta correcta es: Validar esquema, host, ruta, parámetros y estado de autorización antes de ejecutar la acción.

Pregunta 15

Correcta

Se puntúa 1,00 sobre 1,00

Una debilidad relacionada con certificate pinning ausente o comunicación insegura se relaciona principalmente con qué grupo MASVS?

a. MASVS-STORAGE.
b. MASVS-CODE únicamente.
c. MASVS-RESILIENCE únicamente.
d. MASVS-NETWORK. ✓

La respuesta correcta es: MASVS-NETWORK.

Pregunta 16

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué guardar datos sensibles en /sdcard o almacenamiento externo aumenta el riesgo?

a. Porque SQLite no funciona en almacenamiento externo.
b. Porque ese espacio no ofrece las mismas garantías de aislamiento que el almacenamiento privado de la app. ✓
c. Porque Android cifra automáticamente /data/data pero nunca cifra memoria RAM.
d. Porque todo archivo externo se publica en Internet.

La respuesta correcta es: Porque ese espacio no ofrece las mismas garantías de aislamiento que el almacenamiento privado de la app.

Pregunta 17

Correcta

Se puntúa 1,00 sobre 1,00

apktool y jadx muestran resultados diferentes sobre un método ofuscado. ¿Qué interpretación es más apropiada?

a. jadx siempre representa exactamente el bytecode ejecutado.
b. apktool reconstruye el código fuente Kotlin original.
c. Las diferencias prueban que el APK está corrupto.
d. El Java reconstruido por jadx es aproximado; el smali generado por apktool es más fiel al bytecode y puede usarse para confirmar la lógica. ✓

La respuesta correcta es: El Java reconstruido por jadx es aproximado; el smali generado por apktool es más fiel al bytecode y puede usarse para confirmar la lógica.

Pregunta 18

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué un permiso protectionLevel="normal" no constituye una barrera fuerte para un componente exportado?

a. Porque equivale a android:exported="false".
b. Porque Android nunca aplica permisos normal.
c. Porque cualquier aplicación puede solicitarlo sin aprobación del usuario, por lo que no excluye a una app maliciosa.
d. Porque solo funciona en Android 12.

La respuesta correcta es: Porque cualquier aplicación puede solicitarlo sin aprobación del usuario, por lo que no excluye a una app maliciosa.

Pregunta 19

Correcta

Se puntúa 1,00 sobre 1,00

Una app usa ofuscación R8. ¿Cuál es la conclusión correcta respecto de la seguridad del binario?

a. R8 elimina la necesidad de controles del servidor.
b. La ofuscación aumenta el costo de ingeniería inversa, pero no debe considerarse una barrera criptográfica ni impedir el análisis a un adversario motivado.
c. R8 protege automáticamente secretos hardcodeados.
d. R8 hace imposible decompilar cualquier APK.

La respuesta correcta es: La ofuscación aumenta el costo de ingeniería inversa, pero no debe considerarse una barrera criptográfica ni impedir el análisis a un adversario motivado.

Pregunta 20

Correcta

Se puntúa 1,00 sobre 1,00

Un método local checkPin devuelve boolean y no consulta al servidor. ¿Qué demuestra un hook que fuerza true?

a. Que el PIN real fue recuperado.
b. Que el APK está firmado con una clave débil.
c. Que una decisión de seguridad exclusivamente del lado cliente puede ser alterada por quien controla el runtime.
d. Que TLS fue comprometido.

La respuesta correcta es: Que una decisión de seguridad exclusivamente del lado cliente puede ser alterada por quien controla el runtime.

Pregunta 21

Correcta

Se puntúa 1,00 sobre 1,00

Durante una auditoría se encuentra una Activity con android:exported="true". ¿Qué conclusión es técnicamente más correcta antes de reportarla como vulnerabilidad?

a. Solo debe verificarse si la Activity aparece en jadx, porque el Manifest puede ser engañoso.
b. La Activity es vulnerable por definición porque cualquier componente exportado constituye una falla crítica.
c. Debe determinarse si la exportación es necesaria, qué permisos la protegen, qué entradas acepta y qué impacto produce su invocación externa. ✓
d. Debe clasificarse automáticamente como M9 porque todo componente exportado expone datos.

La respuesta correcta es: Debe determinarse si la exportación es necesaria, qué permisos la protegen, qué entradas acepta y qué impacto produce su invocación externa.

Pregunta 22

Correcta

Se puntúa 1,00 sobre 1,00

Un ContentProvider exportado construye una cláusula WHERE concatenando selection recibido del llamador. ¿Qué riesgo adicional debe evaluarse?

a. Insufficient Binary Protections.
b. Certificate pinning.
c. SQL injection a través de parámetros controlados por el llamador. ✓
d. Task hijacking.

La respuesta correcta es: SQL injection a través de parámetros controlados por el llamador.

Pregunta 23

Correcta

Se puntúa 1,00 sobre 1,00

En la cadena Observación -> Hipótesis -> Validación -> Contexto -> Impacto -> Conclusión, ¿por qué Contexto e Impacto son esenciales?

a. Porque reemplazan la necesidad de evidencia.
b. Porque permiten omitir la validación.
c. Porque convierten automáticamente cualquier exposición en crítica.
d. Porque permiten distinguir una condición técnica observable de una vulnerabilidad relevante y justificar su severidad en el escenario real. ✓

La respuesta correcta es: Porque permiten distinguir una condición técnica observable de una vulnerabilidad relevante y justificar su severidad en el escenario real.

Pregunta 24

Correcta

Se puntúa 1,00 sobre 1,00

Una app usa AES-GCM pero fija el mismo IV para todos los mensajes. ¿Cuál es la evaluación adecuada?

a. La reutilización de IV compromete propiedades de seguridad; el IV debe ser nuevo y no repetirse según el esquema.
b. Un IV fijo protege mejor contra replay.
c. El uso de GCM vuelve irrelevante el IV.
d. El único problema es de rendimiento.

La respuesta correcta es: La reutilización de IV compromete propiedades de seguridad; el IV debe ser nuevo y no repetirse según el esquema.

Pregunta 25

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué instalar la CA de Burp como certificado de sistema no garantiza interceptar todas las aplicaciones?

a. Porque adb root deshabilita la red.
b. Porque una app puede aplicar pinning u otras verificaciones adicionales independientes del trust store del sistema.
c. Porque HTTPS nunca puede interceptarse en un emulador.
d. Porque Android no permite certificados de sistema.

La respuesta correcta es: Porque una app puede aplicar pinning u otras verificaciones adicionales independientes del trust store del sistema.

Pregunta 26

Correcta

Se puntúa 1,00 sobre 1,00

Una app detecta root mediante isDeviceRooted() y bloquea el acceso. ¿Qué aprendizaje de diseño surge si forzar false elimina el bloqueo?

a. Frida elimina físicamente el root del dispositivo.
b. La detección de root debería reemplazar autenticación del servidor.
c. El control de seguridad depende de una decisión modificable del lado cliente y no debe considerarse una frontera de confianza absoluta.
d. El APK ya no necesita firma.

La respuesta correcta es: El control de seguridad depende de una decisión modificable del lado cliente y no debe considerarse una frontera de confianza absoluta.

Pregunta 27

Correcta

Se puntúa 1,00 sobre 1,00

Un AVD x86_64 recibe por error un frida-server arm64. ¿Qué resultado es esperable?

a. Frida traducirá automáticamente el binario usando ART.
b. El binario no debería ejecutarse correctamente porque la arquitectura del servidor debe coincidir con la del dispositivo. ✓
c. El servidor funcionará si se ejecuta como root.
d. Solo fallarán los hooks nativos, pero Java.perform funcionará.

La respuesta correcta es: El binario no debería ejecutarse correctamente porque la arquitectura del servidor debe coincidir con la del dispositivo.

Pregunta 28

Correcta

Se puntúa 1,00 sobre 1,00

frida-ps -U no lista procesos después de copiar frida-server al dispositivo. ¿Qué comprobación tiene mayor prioridad?

a. Reinstalar Burp Suite.
b. Verificar que el nombre del APK coincida con el nombre del servidor Frida.
c. Convertir el certificado CA a DER.
d. Verificar arquitectura del dispositivo, versión compatible del servidor, permisos de ejecución y que frida-server esté realmente corriendo. ✓

La respuesta correcta es: Verificar arquitectura del dispositivo, versión compatible del servidor, permisos de ejecución y que frida-server esté realmente corriendo.

Pregunta 29

Correcta

Se puntúa 1,00 sobre 1,00

Una app requiere NFC real y se niega a operar correctamente en AVD. ¿Cuál es la decisión metodológica más adecuada?

a. Usar el teléfono personal porque es la única forma de obtener NFC.
b. Modificar el Manifest para eliminar todos los permisos.
c. Abandonar la evaluación porque el emulador es obligatorio.
d. Usar un teléfono físico dedicado y controlado, manteniendo las mismas reglas de contención. ✓

La respuesta correcta es: Usar un teléfono físico dedicado y controlado, manteniendo las mismas reglas de contención.

Pregunta 30

Correcta

Se puntúa 1,00 sobre 1,00

Una app exportada recibe un Intent que contiene otro Intent y ejecuta startActivity sobre él sin validarlo. ¿Qué vulnerabilidad describe mejor el escenario?

a. Intent redirection, porque la app puede actuar como intermediaria para alcanzar un destino elegido por el atacante.
b. SQL injection.
c. Insufficient Cryptography.
d. Certificate pinning.

La respuesta correcta es: Intent redirection, porque la app puede actuar como intermediaria para alcanzar un destino elegido por el atacante.

Pregunta 31

Correcta

Se puntúa 1,00 sobre 1,00

Un analista obtiene el APK de una aplicación y descubre una clave API embebida en strings.xml. ¿Cuál es el razonamiento más sólido?

a. La clave solo es recuperable si la aplicación tiene android:debuggable="true".
b. Debe asumirse que cualquier dato incluido en el APK puede ser recuperado y luego evaluarse qué privilegios reales concede esa clave.
c. El hallazgo es crítico automáticamente, independientemente de los permisos o alcance de la clave.
d. La clave debe considerarse secreta porque strings.xml queda compilado dentro del APK.

La respuesta correcta es: Debe asumirse que cualquier dato incluido en el APK puede ser recuperado y luego evaluarse qué privilegios reales concede esa clave.

Pregunta 32

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes conjuntos constituye mejor evidencia mínima reproducible?

a. Solo el resultado de MobSF.
b. Solo screenshots finales.
c. Nombre de la vulnerabilidad y severidad.
d. Hash del APK, versión/build, entorno Android, pasos o comandos exactos, salida cruda y fragmento que muestre causa raíz.

La respuesta correcta es: Hash del APK, versión/build, entorno Android, pasos o comandos exactos, salida cruda y fragmento que muestre causa raíz.

Pregunta 33

Correcta

Se puntúa 1,00 sobre 1,00

Una app utiliza AES-GCM con IV aleatorio, pero deriva la clave de una contraseña hardcodeada en código. ¿Cuál es el análisis correcto?

a. El uso de GCM vuelve segura cualquier clave.
b. El IV aleatorio protege la contraseña hardcodeada.
c. No existe riesgo porque GCM autentica el mensaje.
d. La construcción sigue siendo débil por la gestión de la clave, aunque el modo criptográfico sea adecuado. ✓

La respuesta correcta es: La construcción sigue siendo débil por la gestión de la clave, aunque el modo criptográfico sea adecuado.

Pregunta 34

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué un PendingIntent mutable con campos incompletos puede ser riesgoso?

a. Porque desactiva el sandbox.
b. Porque permite modificar la firma del APK.
c. Porque obliga a habilitar cleartext.
d. El receptor puede modificar campos y provocar una acción ejecutada con la identidad o privilegios de la app que creó el PendingIntent. ✓

La respuesta correcta es: El receptor puede modificar campos y provocar una acción ejecutada con la identidad o privilegios de la app que creó el PendingIntent.

Pregunta 35

Correcta

Se puntúa 1,00 sobre 1,00

Desde un AVD de Android Studio se desea enviar tráfico a Burp ejecutándose en la máquina anfitriona. ¿Qué dirección especial puede representar al host desde el emulador?

a. 10.0.2.2 ✓
b. 255.255.255.255
c. 0.0.0.0
d. 127.0.0.1

La respuesta correcta es: 10.0.2.2

Pregunta 36

Correcta

Se puntúa 1,00 sobre 1,00

Una aplicación guarda Base64(password) y lo describe como 'cifrado'. ¿Cuál es la crítica correcta?

a. Base64 es cifrado simétrico pero con una clave pública.
b. Base64 es equivalente a AES-ECB.
c. Base64 es una codificación reversible sin clave, por lo que no proporciona confidencialidad criptográfica. ✓
d. Base64 es seguro si el string no termina en =.

La respuesta correcta es: Base64 es una codificación reversible sin clave, por lo que no proporciona confidencialidad criptográfica.

Pregunta 37

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué función cumple MASWE dentro del ecosistema descrito?

a. Catalogar debilidades móviles concretas y servir como puente de nomenclatura entre controles y debilidades. ✓
b. Firmar APK.
c. Calcular automáticamente CVSS.
d. Definir versiones de Android soportadas.

La respuesta correcta es: Catalogar debilidades móviles concretas y servir como puente de nomenclatura entre controles y debilidades.

Pregunta 38

Correcta

Se puntúa 1,00 sobre 1,00

Un grep encuentra Cipher.getInstance en el código decompilado. ¿Qué debe ocurrir antes de reportar criptografía insegura?

a. Nada; la presencia de Cipher es suficiente.
b. Debe analizarse el algoritmo, modo, padding, gestión de claves e IV usados en la llamada concreta. ✓
c. Debe reemplazarse Cipher por Base64 para comprobar el resultado.
d. Debe clasificarse automáticamente como M7.

La respuesta correcta es: Debe analizarse el algoritmo, modo, padding, gestión de claves e IV usados en la llamada concreta.

Pregunta 39

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diferencia funcional existe entre MASVS y MASTG?

a. No existe diferencia.
b. MASVS define qué controles deben verificarse; MASTG describe cómo probarlos mediante técnicas y casos de prueba. ✓
c. MASTG reemplaza OWASP Mobile Top 10.
d. MASVS contiene exploits y MASTG solo severidades.

La respuesta correcta es: MASVS define qué controles deben verificarse; MASTG describe cómo probarlos mediante técnicas y casos de prueba.

Pregunta 40

Correcta

Se puntúa 1,00 sobre 1,00

LabVault aplica XOR con una clave hardcoded y después Base64. ¿Por qué la combinación sigue siendo débil?

a. Porque ambas operaciones son reversibles y la clave XOR está disponible en el propio cliente. ✓
b. Porque Android no soporta XOR.
c. Porque Base64 destruye la clave.
d. Porque XOR requiere un certificado TLS.

La respuesta correcta es: Porque ambas operaciones son reversibles y la clave XOR está disponible en el propio cliente.

Pregunta 41

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué AES-ECB puede filtrar estructura aunque AES como algoritmo sea fuerte?

a. Porque AES-ECB solo usa claves de 8 bits.
b. Porque ECB publica la clave.
c. Porque ECB convierte el resultado a Base64.
d. Porque bloques iguales de texto producen bloques iguales de cifrado, revelando patrones. ✓

La respuesta correcta es: Porque bloques iguales de texto producen bloques iguales de cifrado, revelando patrones.

Pregunta 42

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál es la relación correcta entre objection y Frida?

a. objection reemplaza el frida-server por Burp.
b. Frida depende de objection para ejecutar cualquier hook.
c. Son herramientas sin relación.
d. objection es una capa construida sobre Frida que ofrece comandos preparados para tareas frecuentes. ✓

La respuesta correcta es: objection es una capa construida sobre Frida que ofrece comandos preparados para tareas frecuentes.

Pregunta 43

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál es la principal razón operativa para usar un dispositivo o emulador dedicado y sin cuentas personales?

a. Permitir que Android ignore todos los permisos.
b. Aumentar la velocidad de jadx.
c. Evitar que una muestra potencialmente maliciosa o una prueba invasiva exponga datos personales, credenciales o redes reales del analista. ✓
d. Evitar calcular hashes del APK.

La respuesta correcta es: Evitar que una muestra potencialmente maliciosa o una prueba invasiva exponga datos personales, credenciales o redes reales del analista.

Pregunta 44

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes pares herramienta/propósito está mejor justificado?

a. jadx para modificar smali y apktool para reconstruir Java exacto.
b. MobSF para reemplazar cualquier validación manual del analista.
c. adb para decompilar classes.dex y Frida para firmar APK.
d. apktool para recursos, Manifest y smali editable; jadx para reconstruir una representación Java legible de la lógica. ✓

La respuesta correcta es: apktool para recursos, Manifest y smali editable; jadx para reconstruir una representación Java legible de la lógica.

Pregunta 45

Correcta

Se puntúa 1,00 sobre 1,00

Una app recibe target desde un Intent y ejecuta web.loadUrl(target) sin validar esquema ni host. ¿Cuál es el riesgo principal?

a. El WebView pierde acceso a Internet.
b. El llamador puede controlar qué contenido carga el WebView, habilitando phishing o cadenas más graves si existen otras configuraciones peligrosas. ✓
c. El Intent deja de ser exportado.
d. Android convertirá automáticamente la URL a HTTPS.

La respuesta correcta es: El llamador puede controlar qué contenido carga el WebView, habilitando phishing o cadenas más graves si existen otras configuraciones peligrosas.

Pregunta 46

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué riesgo de interpretación existe si el analista afirma 'pinning roto' sin documentar que el pinning existía?

a. Puede atribuir como bypass una situación donde la aplicación nunca implementó pinning. ✓
b. Puede impedir que jadx abra el APK.
c. Puede convertir M5 en M10 automáticamente.
d. Puede cambiar el hash del servidor.

La respuesta correcta es: Puede atribuir como bypass una situación donde la aplicación nunca implementó pinning.

Pregunta 47

Correcta

Se puntúa 1,00 sobre 1,00

Un estudiante instala la CA de Burp como certificado de usuario en Android 11. El navegador intercepta correctamente, pero la aplicación no confía en la CA. ¿Cuál es la explicación más consistente?

a. Desde Android 7 las aplicaciones no confían por defecto en CAs de usuario; puede requerirse instalar la CA como certificado de sistema, salvo otras defensas como pinning. ✓
b. La CA debe almacenarse dentro del APK de la aplicación.
c. El problema demuestra necesariamente certificate pinning.
d. Burp no soporta Android 11.

La respuesta correcta es: Desde Android 7 las aplicaciones no confían por defecto en CAs de usuario; puede requerirse instalar la CA como certificado de sistema, salvo otras defensas como pinning.

Pregunta 48

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes resultados sería insuficiente para afirmar que existe pinning?

a. El navegador funciona a través de Burp, la CA es confiable y la app falla solo con el proxy.
b. La app no carga datos cuando se activa Burp, sin haber comprobado si el navegador y el proxy funcionan correctamente. ✓
c. Al desactivar el proxy la app vuelve a funcionar.
d. Un bypass específico de pinning hace aparecer el tráfico.

La respuesta correcta es: La app no carga datos cuando se activa Burp, sin haber comprobado si el navegador y el proxy funcionan correctamente.

Pregunta 49

Correcta

Se puntúa 1,00 sobre 1,00

Una clave AES de 256 bits está hardcodeada en el APK. ¿Qué debilidad domina el análisis?

a. La longitud de clave es insuficiente.
b. El problema desaparece si se aplica Base64.
c. El APK ya no puede decompilarse.
d. La clave puede recuperarse del binario, por lo que la fortaleza de AES no compensa una gestión de claves insegura. ✓

La respuesta correcta es: La clave puede recuperarse del binario, por lo que la fortaleza de AES no compensa una gestión de claves insegura.

Pregunta 50

Correcta

Se puntúa 1,00 sobre 1,00

El proxy funciona para el navegador del AVD y la CA de Burp está como sistema, pero una app corta la conexión TLS. ¿Cuál es la hipótesis más fuerte?

a. Burp no puede interceptar HTTPS.
b. El AVD perdió conectividad IP por definición.
c. La app podría implementar certificate pinning. ✓
d. El Manifest no contiene permisos.

La respuesta correcta es: La app podría implementar certificate pinning.

Pregunta 51

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál es la mejor justificación para implementar defensas de resiliencia si ninguna es infalible?

a. Impedir matemáticamente toda ingeniería inversa.
b. Eliminar la necesidad de autenticación.
c. Convertir una app cliente en un entorno confiable.
d. Aumentar costo y tiempo del análisis/manipulación, detectar ciertos entornos y dificultar ataques oportunistas, sin asumir que sustituyen controles de seguridad reales. ✓

La respuesta correcta es: Aumentar costo y tiempo del análisis/manipulación, detectar ciertos entornos y dificultar ataques oportunistas, sin asumir que sustituyen controles de seguridad reales.

Pregunta 52

Correcta

Se puntúa 1,00 sobre 1,00

Durante una prueba aparece un dato personal real no necesario para demostrar la falla. ¿Qué actuación es más profesional?

a. Publicarlo en el repositorio de evidencias del curso.
b. Compartirlo con otros grupos para validar reproducibilidad.
c. Copiarlo completo al informe para demostrar impacto.
d. Minimizar su tratamiento, documentar el hallazgo sin exfiltrar más información de la necesaria y preservar solo la evidencia imprescindible. ✓

La respuesta correcta es: Minimizar su tratamiento, documentar el hallazgo sin exfiltrar más información de la necesaria y preservar solo la evidencia imprescindible.

Pregunta 53

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál de los siguientes resultados de búsqueda merece mayor prioridad de revisión contextual?

a. Una llamada Runtime.getRuntime().exec donde el argumento deriva de una entrada externa. ✓
b. Una referencia a Log.d("TAG", "inicio") sin datos.
c. Una cadena https://developer.android.com.
d. Una instancia de SharedPreferences que almacena un booleano de interfaz no sensible.

La respuesta correcta es: Una llamada Runtime.getRuntime().exec donde el argumento deriva de una entrada externa.

Pregunta 54

Correcta

Se puntúa 1,00 sobre 1,00

Un componente debe ser exportado para interoperar con apps del mismo proveedor. ¿Cuál es la remediación más adecuada frente a una exposición innecesaria al resto del sistema?

a. Marcar toda la aplicación debuggable.
b. Usar un permiso normal.
c. Eliminar toda validación para simplificar IPC.
d. Protegerlo con un permiso signature y validar las entradas recibidas. ✓

La respuesta correcta es: Protegerlo con un permiso signature y validar las entradas recibidas.

Pregunta 55

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué la protección del binario se clasifica separadamente de la criptografía de datos?

a. Porque dificultar análisis o manipulación del APK y proteger confidencialidad/integridad de datos mediante criptografía son objetivos relacionados pero distintos. ✓
b. Porque la ofuscación cifra todas las bases de datos.
c. Porque el Keystore reemplaza la ofuscación.
d. Porque M7 y M10 son equivalentes.

La respuesta correcta es: Porque dificultar análisis o manipulación del APK y proteger confidencialidad/integridad de datos mediante criptografía son objetivos relacionados pero distintos.

Pregunta 56

Correcta

Se puntúa 1,00 sobre 1,00

Un valor sensible está cifrado con una clave almacenada como string dentro del mismo APK. ¿Cuál es la evaluación más adecuada?

a. El cifrado es suficiente porque el archivo almacenado no está en texto claro.
b. La confidencialidad es débil porque un analista puede recuperar la clave del APK y descifrar el dato. ✓
c. El problema solo existe si se usa SQLite.
d. La clave hardcoded es segura si el APK tiene ofuscación.

La respuesta correcta es: La confidencialidad es débil porque un analista puede recuperar la clave del APK y descifrar el dato.

Pregunta 57

Correcta

Se puntúa 1,00 sobre 1,00

Una Activity exportada permite abrir una pantalla administrativa, pero la propia Activity vuelve a validar una sesión válida antes de mostrar contenido. ¿Cuál es la conclusión más precisa?

a. El control de sesión no tiene valor porque toda Activity exportada ignora autenticación.
b. La exportación es automáticamente crítica.
c. Debe clasificarse directamente como M10.
d. El componente está expuesto, pero la validación interna puede impedir el bypass; debe comprobarse si existe impacto real. ✓

La respuesta correcta es: El componente está expuesto, pero la validación interna puede impedir el bypass; debe comprobarse si existe impacto real.

Pregunta 58

Correcta

Se puntúa 1,00 sobre 1,00

Una app almacena un token de sesión en SharedPreferences en texto claro. ¿Cuál es el impacto más directo si un atacante obtiene acceso al sandbox?

a. Puede firmar nuevas versiones de la aplicación.
b. Puede modificar el kernel de Android.
c. Puede deshabilitar TLS en el servidor.
d. Puede reutilizar potencialmente la sesión sin conocer la contraseña. ✓

La respuesta correcta es: Puede reutilizar potencialmente la sesión sin conocer la contraseña.

Pregunta 59

Correcta

Se puntúa 1,00 sobre 1,00

Durante la revisión de una aplicación se detecta un Log.d que imprime la cadena "login successful". ¿Qué debe hacer el analista?

a. Determinar qué información concreta se registra y si el log expone datos sensibles antes de concluir que existe un hallazgo. ✓
b. Clasificarlo como M10 porque los logs no están cifrados.
c. Eliminar el Log.d del APK y considerar la vulnerabilidad corregida.
d. Reportarlo como fuga de información sensible M9.

La respuesta correcta es: Determinar qué información concreta se registra y si el log expone datos sensibles antes de concluir que existe un hallazgo.

Pregunta 60

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué registrar el hash SHA-256 del APK es relevante para la validez de un hallazgo?

a. Porque permite descifrar recursos protegidos del APK.
b. Porque vincula las evidencias y conclusiones con un binario concreto y evita atribuir el hallazgo a otro build. ✓
c. Porque reemplaza la necesidad de registrar versionName y versionCode.
d. Porque Android solo permite instalar APK cuyo hash fue calculado previamente.

La respuesta correcta es: Porque vincula las evidencias y conclusiones con un binario concreto y evita atribuir el hallazgo a otro build.

Pregunta 61

Correcta

Se puntúa 1,00 sobre 1,00

Un XSS se ejecuta dentro de un WebView que expone un puente Java con acceso a datos de sesión. ¿Por qué el impacto puede superar al de un XSS web convencional?

a. Porque todos los WebView ejecutan como root.
b. Porque el JavaScript puede alcanzar capacidades nativas expuestas por la app y datos del sandbox a través del puente. ✓
c. Porque el navegador externo no soporta JavaScript.
d. Porque XSS deshabilita SELinux.

La respuesta correcta es: Porque el JavaScript puede alcanzar capacidades nativas expuestas por la app y datos del sandbox a través del puente.

Pregunta 62

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué condición vuelve especialmente peligrosa a addJavascriptInterface?

a. Que el método Java sea public.
b. Que la aplicación use HTTPS.
c. Que el Manifest tenga INTERNET.
d. Que el WebView pueda cargar contenido controlado por un atacante y el puente exponga métodos sensibles a JavaScript. ✓

La respuesta correcta es: Que el WebView pueda cargar contenido controlado por un atacante y el puente exponga métodos sensibles a JavaScript.

Pregunta 63

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué ventaja ofrece un hook de Frida frente a reempaquetar network_security_config?

a. Puede modificar verificaciones en runtime sin reconstruir el APK, incluso cuando la lógica de confianza está implementada en código.

b. Firma automáticamente la aplicación con su clave original.

c. Elimina el tráfico TLS del servidor.

d. Evita toda necesidad de root en cualquier escenario.

La respuesta correcta es: Puede modificar verificaciones en runtime sin reconstruir el APK, incluso cuando la lógica de confianza está implementada en código.

Pregunta 64

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué evidencia demuestra mejor que una Activity exportada genera un bypass de autenticación?

a. Un resultado de MobSF con severidad alta.

b. El nombre SecretActivity.

c. La combinación de Manifest que muestra exportación sin protección y una prueba reproducible que abre contenido restringido sin pasar por el login.

d. Una captura del Manifest únicamente.

La respuesta correcta es: La combinación de Manifest que muestra exportación sin protección y una prueba reproducible que abre contenido restringido sin pasar por el login.

Pregunta 65

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué propiedad del Android Keystore mejora la protección de claves?

a. Impide cualquier instrumentación del proceso.

b. Evita que la app sea desinstalada.

c. Permite generar y usar claves sin almacenarlas como literales recuperables dentro del APK y, cuando el hardware lo soporta, mantenerlas protegidas por hardware.

d. Oculta todas las URLs del APK.

La respuesta correcta es: Permite generar y usar claves sin almacenarlas como literales recuperables dentro del APK y, cuando el hardware lo soporta, mantenerlas protegidas por hardware.

Pregunta 66

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué función cumple Java.perform en un script Frida para Android?

a. Convierte Java a smali.
b. Firma el APK.
c. Asegura que la interacción con clases Java ocurra cuando el runtime está disponible. ✓
d. Instala automáticamente frida-server.

La respuesta correcta es: Asegura que la interacción con clases Java ocurra cuando el runtime está disponible.

Pregunta 67

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué setAllowUniversalAccessFromFileURLs(true) es más riesgoso que permitir solo acceso local a archivos?

a. Porque una página cargada desde file:// puede acceder a otros recursos locales y realizar solicitudes a otros orígenes, ampliando la capacidad de exfiltración. ✓
b. Porque deshabilita JavaScript.
c. Porque obliga a usar App Links.
d. Porque evita leer archivos locales.

La respuesta correcta es: Porque una página cargada desde file:// puede acceder a otros recursos locales y realizar solicitudes a otros orígenes, ampliando la capacidad de exfiltración.

Pregunta 68

Correcta

Se puntúa 1,00 sobre 1,00

Un hallazgo de almacenamiento local inseguro debería mapearse prioritariamente a qué grupo MASVS?

a. MASVS-STORAGE. ✓
b. MASVS-RESILIENCE.
c. MASVS-PRIVACY exclusivamente.
d. MASVS-NETWORK.

La respuesta correcta es: MASVS-STORAGE.

Pregunta 69

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diferencia existe entre spawn (-f) y engancharse a un proceso ya iniciado?

a. Adjuntarse tarde permite modificar el APK en disco.

b. Con spawn puede instrumentarse desde el arranque y observar código ejecutado tempranamente; al adjuntarse tarde pueden perderse esas llamadas iniciales. ✓

c. Spawn solo funciona en iOS.

d. No existe ninguna diferencia.

La respuesta correcta es: Con spawn puede instrumentarse desde el arranque y observar código ejecutado tempranamente; al adjuntarse tarde pueden perderse esas llamadas iniciales.

Pregunta 70

Correcta

Se puntúa 1,00 sobre 1,00

Una aplicación targetea Android 12 y define un componente con intent-filter. ¿Qué requisito relevante introduce esta versión?

a. android:debuggable debe ser true.

b. android:exported debe declararse explícitamente. ✓

c. Los deep links dejan de funcionar.

d. Todos los permisos deben ser signature.

La respuesta correcta es: android:exported debe declararse explícitamente.

Pregunta 71

Correcta

Se puntúa 1,00 sobre 1,00

objection desactiva el pinning y el tráfico comienza a verse. ¿Qué interpretación es más adecuada?

a. Se probó que la app usa HTTP en claro.

b. Se confirmó que el proxy estaba mal configurado.

c. Se demostró una vulnerabilidad del servidor.

d. El comportamiento es consistente con una validación de certificado del lado cliente que fue neutralizada dinámicamente. ✓

La respuesta correcta es: El comportamiento es consistente con una validación de certificado del lado cliente que fue neutralizada dinámicamente.

Pregunta 72

Correcta

Se puntúa 1,00 sobre 1,00

El navegador del AVD aparece en Burp, pero la aplicación auditada deja de cargar únicamente cuando el proxy está configurado. ¿Cuál es el siguiente diagnóstico razonable?

a. Existe un indicio de certificate pinning o de una política de confianza adicional específica de la aplicación.
b. adb dejó de reconocer el dispositivo.
c. El APK se volvió incompatible con la arquitectura del AVD.
d. El proxy general está necesariamente mal configurado.

La respuesta correcta es: Existe un indicio de certificate pinning o de una política de confianza adicional específica de la aplicación.

Pregunta 73

Correcta

Se puntúa 1,00 sobre 1,00

pm path devuelve base.apk y varios split_config.*.apk. ¿Cuál es la acción más adecuada para preservar el artefacto analizado?

a. Recuperar todas las rutas devueltas para conservar el conjunto de APK que compone la instalación.
b. Convertir los splits a archivos dex manualmente antes de copiarlos.
c. Descargar solo base.apk porque los splits nunca contienen recursos relevantes.
d. Ejecutar únicamente strings sobre base.apk.

La respuesta correcta es: Recuperar todas las rutas devueltas para conservar el conjunto de APK que compone la instalación.

Pregunta 74

Correcta

Se puntúa 1,00 sobre 1,00

Un logcat muestra un token de acceso durante el login. ¿Qué evidencia adicional fortalece el hallazgo?

a. Demostrar que el valor registrado corresponde realmente a un token válido o sensible y documentar el punto de código que lo imprime.
b. Mostrar que Log.d existe en Android.
c. Modificar el token en el servidor.
d. Probar que el APK contiene iconos.

La respuesta correcta es: Demostrar que el valor registrado corresponde realmente a un token válido o sensible y documentar el punto de código que lo imprime.

Pregunta 75

Correcta

Se puntúa 1,00 sobre 1,00

Un WebView tiene JavaScript habilitado, pero solo carga contenido empaquetado y controlado por la aplicación. ¿Cuál es la evaluación más precisa?

a. El riesgo aumenta cuando contenido no confiable puede llegar al WebView; debe evaluarse la cadena completa antes de reportar.
b. JavaScript habilitado es una vulnerabilidad crítica por sí solo.
c. Debe clasificarse como M10.
d. Todo WebView con JavaScript implica RCE.

La respuesta correcta es: El riesgo aumenta cuando contenido no confiable puede llegar al WebView; debe evaluarse la cadena completa antes de reportar.

Pregunta 76

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diferencia de riesgo existe entre un Intent explícito y uno implícito según el material?

a. El explícito dirige a un componente concreto; el implícito depende de resolución del sistema y puede introducir riesgos de redirección o hijacking.
b. El implícito nunca puede transportar datos.
c. El explícito siempre atraviesa Internet.
d. Ambos tienen exactamente la misma superficie.

La respuesta correcta es: El explícito dirige a un componente concreto; el implícito depende de resolución del sistema y puede introducir riesgos de redirección o hijacking.

Pregunta 77

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué ventaja de seguridad tienen los App Links verificados frente a esquemas personalizados tipo miapp://?

a. Los App Links no usan Intents.
b. Los esquemas personalizados siempre requieren permisos signature.
c. La asociación con el dominio puede verificarse mediante assetlinks.json, reduciendo el riesgo de que otra app reclame el mismo enlace.
d. Los App Links no transportan parámetros.

La respuesta correcta es: La asociación con el dominio puede verificarse mediante assetlinks.json, reduciendo el riesgo de que otra app reclame el mismo enlace.

Pregunta 78

Correcta

Se puntúa 1,00 sobre 1,00

Una aplicación moderna está dividida en múltiples APK. ¿Qué riesgo metodológico existe si se analiza únicamente base.apk?

a. jadx no admite archivos APK base.
b. Se pueden omitir recursos, configuraciones o módulos presentes en splits y obtener una visión incompleta del build instalado. ✓
c. El hash SHA-256 deja de funcionar.
d. Ninguno; todos los recursos y código siempre están exclusivamente en base.apk.

La respuesta correcta es: Se pueden omitir recursos, configuraciones o módulos presentes en splits y obtener una visión incompleta del build instalado.

Pregunta 79

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué afirmación sobre el almacenamiento privado Android es más precisa?

a. Es inaccesible incluso para el propio proceso de la aplicación.
b. Elimina la necesidad de clasificar sensibilidad.
c. Convierte automáticamente todos los datos en AES-GCM.
d. Protege contra otras apps en condiciones normales, pero no debe asumirse suficiente frente a root, debuggable, backups u otros accesos al dispositivo. ✓

La respuesta correcta es: Protege contra otras apps en condiciones normales, pero no debe asumirse suficiente frente a root, debuggable, backups u otros accesos al dispositivo.

Pregunta 80

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué una remediación como 'mejorar la seguridad' es insuficiente?

a. Porque no corrige ni identifica la causa técnica concreta y no permite al equipo implementar una acción verificable. ✓
b. Porque las remediaciones no forman parte de un informe.
c. Porque toda remediación debe incluir código Java.
d. Porque solo OWASP puede proponer correcciones.

La respuesta correcta es: Porque no corrige ni identifica la causa técnica concreta y no permite al equipo implementar una acción verificable.

Pregunta 81

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué propiedad del modelo Android explica mejor por qué el pentesting móvil difiere del pentesting web tradicional?

a. El código del servidor Android siempre se descarga junto con el APK.
b. El atacante puede poseer el binario cliente y analizar código, recursos, manifiesto y lógica local sin depender de inferencias sobre el servidor. ✓
c. Las aplicaciones Android no utilizan cifrado TLS.
d. Android no implementa aislamiento entre aplicaciones.

La respuesta correcta es: El atacante puede poseer el binario cliente y analizar código, recursos, manifiesto y lógica local sin depender de inferencias sobre el servidor.

Pregunta 82

Correcta

Se puntúa 1,00 sobre 1,00

Un hallazgo tiene una hipótesis plausible y una PoC funcional, pero el dato obtenido era público. ¿Qué aspecto debe reconsiderarse especialmente?

a. El formato de firma.
b. El package name.
c. El impacto y por lo tanto la severidad real del hallazgo. ✓
d. El hash del APK.

La respuesta correcta es: El impacto y por lo tanto la severidad real del hallazgo.

Pregunta 83

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué criterio distingue una pista estática de un hallazgo confirmado?

a. El analista puede asociarla con una condición explotable o un impacto demostrable dentro del contexto de la aplicación. ✓
b. La cadena contiene la palabra password.
c. La pista aparece en más de un archivo.
d. El patrón fue encontrado por grep.

La respuesta correcta es: El analista puede asociarla con una condición explotable o un impacto demostrable dentro del contexto de la aplicación.

Pregunta 84

Correcta

Se puntúa 1,00 sobre 1,00

En smali aparece const-string v0, "https://api.interna.example/v1" seguido de una llamada a un método de red. ¿Cuál es la conclusión correcta?

a. El endpoint está cifrado y no puede ser utilizado.
b. Es una pista de endpoint embebido que debe contextualizarse y validarse; la cadena por sí sola no demuestra impacto. ✓
c. Existe automáticamente una vulnerabilidad crítica.
d. La presencia de const-string implica ejecución remota de código.

La respuesta correcta es: Es una pista de endpoint embebido que debe contextualizarse y validarse; la cadena por sí sola no demuestra impacto.

Pregunta 85

Correcta

Se puntúa 1,00 sobre 1,00

En una evaluación se observa un BroadcastReceiver exportado que procesa un extra llamado action. ¿Qué condición convertiría la exposición en un hallazgo demostrable?

a. Que pueda invocarse desde otra aplicación y que un valor controlado externamente produzca una acción no autorizada o un efecto sensible. ✓
b. Que exista al menos un intent-filter en el Manifest.
c. Que el receiver tenga un nombre de clase fácilmente reconocible.
d. Que el APK tenga más de un archivo classes.dex.

La respuesta correcta es: Que pueda invocarse desde otra aplicación y que un valor controlado externamente produzca una acción no autorizada o un efecto sensible.

Pregunta 86

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué diseño mejora la resistencia frente a un bypass puramente lógico de biometría?

a. Usar la autenticación biométrica para autorizar el uso de una clave criptográfica del Keystore en lugar de confiar únicamente en un flag local. ✓
b. Ocultar el método con un nombre corto.
c. Codificar el resultado en Base64.
d. Guardar isAuthenticated=true en SharedPreferences.

La respuesta correcta es: Usar la autenticación biométrica para autorizar el uso de una clave criptográfica del Keystore en lugar de confiar únicamente en un flag local.

Pregunta 87

Correcta

Se puntúa 1,00 sobre 1,00

Una app es debuggable y run-as permite acceder a /data/data/<package>. ¿Qué demuestra esto respecto del modelo de amenaza?

a. Que un atacante con acceso adb puede aprovechar la condición debuggable para acceder al almacenamiento privado de esa app sin root.
b. Que el sandbox deja de existir para todas las apps del dispositivo.
c. Que el APK fue firmado incorrectamente.
d. Que cualquier sitio web remoto puede leer esos archivos.

La respuesta correcta es: Que un atacante con acceso adb puede aprovechar la condición debuggable para acceder al almacenamiento privado de esa app sin root.

Pregunta 88

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué ventaja de smali es especialmente relevante cuando se quiere cambiar el comportamiento de una aplicación?

a. Oculta los nombres de métodos para dificultar la ingeniería inversa.
b. Representa el bytecode en formato textual editable y permite reconstruir el APK con apktool.
c. Permite firmar el APK sin una clave.
d. Evita que Android valide la firma al instalar.

La respuesta correcta es: Representa el bytecode en formato textual editable y permite reconstruir el APK con apktool.

Pregunta 89

Correcta

Se puntúa 1,00 sobre 1,00

Un estudiante configura Burp para escuchar solo en 127.0.0.1 y el AVD usa la IP del host como proxy. ¿Qué problema puede aparecer?

a. El certificado de Burp se convierte automáticamente en inválido.
b. El AVD no puede alcanzar un listener limitado al loopback de la máquina anfitriona.
c. adb remount borra el proxy configurado.
d. Frida deja de funcionar por conflicto de puertos.

La respuesta correcta es: El AVD no puede alcanzar un listener limitado al loopback de la máquina anfitriona.

Pregunta 90

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué problema metodológico produce no registrar criterios de detención antes de una prueba?

a. jadx modifica automáticamente el binario.
b. El APK deja de instalarse.
c. Se pierde una referencia clara sobre cuándo interrumpir acciones que puedan exceder el riesgo o alcance autorizado.
d. El hash SHA-256 cambia.

La respuesta correcta es: Se pierde una referencia clara sobre cuándo interrumpir acciones que puedan exceder el riesgo o alcance autorizado.

Pregunta 91

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál es la corrección más coherente para una base SQLite con datos sensibles almacenados sin cifrar?

a. Codificar cada campo en Base64.
b. Renombrar la extensión .db.
c. Usar una solución de cifrado de base como SQLCipher y gestionar adecuadamente la clave.
d. Mover la base a /sdcard.

La respuesta correcta es: Usar una solución de cifrado de base como SQLCipher y gestionar adecuadamente la clave.

Pregunta 92

Correcta

Se puntúa 1,00 sobre 1,00

Se necesita un AVD para instalar el certificado de Burp como CA de sistema y ejecutar frida-server con privilegios. ¿Qué imagen es la opción más conveniente según el laboratorio?

a. AOSP únicamente, porque ninguna aplicación requiere Google Play Services.
b. Cualquier imagen produce exactamente el mismo comportamiento respecto de root.
c. Google Play, porque incluye la tienda y siempre permite adb root.
d. Google APIs, porque es una build de tipo debug y facilita adb root y el remontaje de /system.

La respuesta correcta es: Google APIs, porque es una build de tipo debug y facilita adb root y el remontaje de /system.

Pregunta 93

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál de las siguientes combinaciones refleja mejor una metodología profesional de pentesting Android?

a. Decompilar, identificar strings sospechosos y reportarlos sin ejecutar la aplicación.
b. Instalar primero la aplicación en el teléfono personal para observar su comportamiento real.
c. Ejecutar scanners automáticos, ordenar por severidad y copiar el resultado al informe.
d. Confirmar alcance, registrar hash, analizar estática y dinámicamente, validar impacto mínimo y documentar evidencia reproducible. ✓

La respuesta correcta es: Confirmar alcance, registrar hash, analizar estática y dinámicamente, validar impacto mínimo y documentar evidencia reproducible.

Pregunta 94

Correcta

Se puntúa 1,00 sobre 1,00

Una aplicación usa pinning correctamente. Desde la perspectiva del pentest, ¿qué significa?

a. Que la aplicación es invulnerable a cualquier ataque.
b. Que constituye una defensa del cliente que dificulta MITM, pero puede evaluarse en un dispositivo controlado mediante instrumentación o modificación autorizada. ✓
c. Que el certificado del servidor está dentro del Android Keystore del pentester.
d. Que ya no es necesario analizar la API.

La respuesta correcta es: Que constituye una defensa del cliente que dificulta MITM, pero puede evaluarse en un dispositivo controlado mediante instrumentación o modificación autorizada.

Pregunta 95

Correcta

Se puntúa 1,00 sobre 1,00

¿Cuál es el efecto de android:exported="false" en un componente?

a. Convierte automáticamente el componente en signature-protected.
b. Impide que incluso la propia aplicación lo invoque.
c. Restringe su invocación a la propia aplicación, evitando acceso directo desde otras apps. ✓
d. Deshabilita todos los intent-filters.

La respuesta correcta es: Restringe su invocación a la propia aplicación, evitando acceso directo desde otras apps.

Pregunta 96

Correcta

Se puntúa 1,00 sobre 1,00

Un analista modifica android:debuggable a true y reconstruye el APK. ¿Por qué debe volver a firmarlo antes de instalarlo?

a. Porque jadx elimina automáticamente META-INF.
b. Porque el atributo debuggable requiere una firma de sistema.
c. Porque adb solo acepta APK firmados con la CA de Burp.
d. Porque cualquier modificación invalida la firma original del paquete. ✓

La respuesta correcta es: Porque cualquier modificación invalida la firma original del paquete.

Pregunta 97

Correcta

Se puntúa 1,00 sobre 1,00

Un hook sobrecarga por error el método equivocado porque una clase tiene varias firmas. ¿Qué consecuencia metodológica tiene?

a. Puede llevar a concluir falsamente que el bypass no funciona; deben identificarse las sobrecargas y firma concreta del método. ✓
b. Frida selecciona siempre la sobrecarga correcta.
c. Android desinstala la aplicación.
d. El APK queda permanentemente modificado.

La respuesta correcta es: Puede llevar a concluir falsamente que el bypass no funciona; deben identificarse las sobrecargas y firma concreta del método.

Pregunta 98

Correcta

Se puntúa 1,00 sobre 1,00

¿Qué combinación representa una configuración global que puede facilitar interceptación de tráfico?

a. debuggable=false y usesCleartextTraffic=false.
b. networkSecurityConfig que confía en certificados de usuario junto con una política permisiva de red. ✓
c. minSdk alto y targetSdk alto.
d. allowBackup=false y exported=false.

La respuesta correcta es: networkSecurityConfig que confía en certificados de usuario junto con una política permisiva de red.

Pregunta 99

Correcta

Se puntúa 1,00 sobre 1,00

¿Por qué un bypass biométrico es especialmente probable cuando la app trata el éxito biométrico como un simple booleano?

a. Porque la biometría deshabilita el Android Keystore.
b. Porque BiometricPrompt siempre acepta cualquier huella.
c. Porque el callback puede ser manipulado en runtime sin que exista una operación criptográfica ligada a una clave protegida.
d. Porque toda autenticación biométrica viaja por HTTP.

La respuesta correcta es: Porque el callback puede ser manipulado en runtime sin que exista una operación criptográfica ligada a una clave protegida.

Pregunta 100

Correcta

Se puntúa 1,00 sobre 1,00

Una vez visible una request en Burp, ¿qué enfoque mantiene mejor el principio de mínima carga de prueba?

a. Modificar parámetros solo lo necesario para validar la hipótesis, usando valores controlados y evitando acciones destructivas.
b. Repetir la request con datos de otros usuarios reales.
c. Eliminar cabeceras al azar hasta provocar errores.
d. Automatizar fuzzing ilimitado contra producción.

La respuesta correcta es: Modificar parámetros solo lo necesario para validar la hipótesis, usando valores controlados y evitando acciones destructivas.